

The MGM Resorts Ransomware Attack (2023)

Suresh L. Paul

2026-03-11

Introduction

In September 2023, MGM Resorts International — one of the largest hotel and casino operators in the world — was brought to its knees by a cyberattack. For ten days, guests at MGM properties in Las Vegas and around the world experienced a cascade of failures: hotel room key cards stopped working, slot machines went dark, digital payment systems went offline, and MGM’s website and apps became inaccessible.

The total cost to MGM was estimated at over **\$100 million** in losses, plus significant reputational damage. And how did the attackers get in? They made a phone call.

This case illustrates one of the most important and uncomfortable truths in cybersecurity: **the most sophisticated technical defenses in the world can be defeated by targeting human beings instead of computer systems.**

Background: MGM Resorts

MGM Resorts International is a global hospitality and entertainment company headquartered in Las Vegas, Nevada. It operates more than 30 hotel and casino properties worldwide, including iconic Las Vegas destinations like the Bellagio, MGM Grand, Aria, and Mandalay Bay.

These properties are profoundly dependent on technology. Thousands of hotel room doors use electronic key cards. Tens of thousands of slot machines and gaming devices are networked together. Guest check-in, restaurant reservations, loyalty programs, payment systems, security cameras, and business operations all rely on interconnected IT systems running 24 hours a day.

Disrupting those systems doesn’t just cause inconvenience — it directly halts revenue generation in one of the most cash-intensive industries in the world.

The Attack: How It Happened

The group responsible for the attack is known by several names in the cybersecurity community, including **ALPHV/BlackCat** and a subgroup called **Scattered Spider**. These are not shadowy state-sponsored hackers in a government facility — Scattered Spider is believed to be a loosely organized group of young English-speaking individuals, some reportedly teenagers or young adults, operating primarily for financial gain.

Their method of entry was strikingly simple.

Step 1: Open-Source Intelligence (OSINT)

The attackers researched MGM employees on **LinkedIn** — the professional networking website. LinkedIn is a goldmine of information for attackers: it lists where people work, what their job title is, and often details about their responsibilities. The attackers identified an MGM IT employee and gathered basic information about that person.

Open-source intelligence (OSINT) refers to gathering information from publicly available sources (websites, social media, news articles) to learn about a target. It costs nothing and requires no hacking skills.

Step 2: The Phone Call — Social Engineering

Armed with the employee's name, job title, and employer, the attackers called **MGM's IT help desk** and impersonated the employee. They claimed to be locked out of their account and needed their access restored.

This technique is called **social engineering** — manipulating people into doing something or revealing information by exploiting human psychology rather than technical vulnerabilities. In this case, the attacker exploited:

- **Authority:** Claiming to be a legitimate employee with a plausible story
- **Urgency:** Help desk staff are trained to help people quickly; a locked-out employee is a routine problem
- **Trust:** Help desk staff deal with hundreds of requests and cannot deeply verify every caller

The help desk complied and reset the employee's access credentials. In doing so, they unknowingly handed the keys to the kingdom to a criminal.

Step 3: The Ransomware Attack

With valid credentials, the attackers accessed MGM's internal systems. They spent time moving through the network, escalating their access privileges, identifying critical systems, and positioning themselves for maximum impact.

They then deployed **ransomware** — malicious software that encrypts (scrambles) the victim's data and systems, making them completely unusable. The attackers then demanded a ransom payment (in cryptocurrency) in exchange for the decryption key needed to restore access.

Ransomware works like a digital padlock on your own files. Imagine arriving at your office to find every filing cabinet, computer, and door locked — and someone calling to say they'll give you the keys for \$30 million. That is essentially what MGM faced.

MGM chose **not to pay the ransom**. This is the recommended approach by most cybersecurity experts and law enforcement agencies (paying rewards criminals and doesn't guarantee the data will be restored), but it meant MGM had to restore its systems the hard way — through backup recovery and manual rebuilding.

The Impact: Ten Days of Chaos

The effects of the attack were immediately visible to anyone at an MGM property:

- **Hotel room key cards** failed at multiple properties, requiring staff to issue manual keys or assist guests manually

- **Casino floors** went dark — slot machines, video poker terminals, and digital gaming systems were taken offline
- **Point-of-sale systems** (cash registers, payment terminals) failed, forcing many transactions to be handled with cash only
- **MGM’s website and mobile app** went offline, preventing reservations and bookings
- **MGM Rewards** — the company’s customer loyalty program — was inaccessible
- **Internal communications** were disrupted, making it harder for staff to coordinate the response
- The hotel-casino at **MGM Grand** reportedly had to pay out slot machine jackpots manually with cash because the tracking systems were down

For ten days, one of the most technologically sophisticated hospitality operations in the world was reduced to operating like it was 1980.

Comparing MGM and Caesars: Two Very Different Responses

What makes this case even more interesting is that another Las Vegas casino giant — **Caesars Entertainment** — was hit by the same group (Scattered Spider) around the same time, using the same social engineering technique.

Caesars chose to **pay the ransom** — reportedly around \$15 million (roughly half of the \$30 million initially demanded). Their attack was barely noticed by the public. Systems were restored quickly. There was minimal operational disruption.

MGM chose not to pay. Their disruption lasted ten days and cost over \$100 million.

This raises a genuine and difficult ethical and practical question: **Is it ever right to pay criminals?** Paying ransom funds criminal enterprises and encourages more attacks. But not paying can cost far more in operational disruption and lost revenue. There is no easy answer, and organizations must think through this question **before** they are attacked.

Why This Happened: An MIS Perspective

1. The Human Element Is the Weakest Link

No matter how sophisticated an organization’s firewalls, encryption, and technical defenses are, human beings remain the most exploitable component. A single help desk employee who followed standard procedure (reset a locked-out account) inadvertently enabled a catastrophic breach.

This is not a criticism of that employee — it is a systemic problem. Organizations must design **verification processes** that make it significantly harder to impersonate an employee, even over the phone.

2. Identity Verification Is a Process Problem

MGM’s help desk did not have a robust process for **verifying the identity** of someone calling to request account access. Best practices include calling the person back at a known number, requiring a secondary verification code, or requiring manager approval for account resets. None of these appear to have been in place.

3. Over-Privileged Access

Once inside the network, the attackers were able to move across systems and eventually access critical infrastructure. This suggests that the compromised account (or accounts subsequently accessed) had broad permissions. **The principle of least privilege** — giving users access only to what they specifically need to do their jobs — is a fundamental security best practice that can limit the damage when credentials are compromised.

4. Insufficient Employee Security Training

Help desk staff and all employees who interact with sensitive systems need regular, realistic training on social engineering tactics. Simply being told “don’t give out passwords” is not enough. People need to experience realistic simulations and understand specifically how attackers will try to manipulate them.

5. Inadequate Business Continuity Planning

While MGM eventually restored its systems, the ten-day disruption suggests that its backup and recovery plans were not sufficient for an attack of this scale. Robust business continuity planning includes regularly tested backups, offline recovery systems, and clear manual operating procedures for when digital systems fail.

Key Concepts for Discussion

Concept	Definition	Relevance to This Case
Social Engineering	Manipulating people to gain unauthorized access	The entire attack began with a phone call
Ransomware	Malicious software that encrypts data and demands payment	The mechanism used to disrupt MGM’s operations
Principle of Least Privilege	Users should have only the access they need	Attackers gained broad access after initial breach
Business Continuity	Plans to maintain operations during disruptions	MGM’s 10-day disruption reveals continuity planning gaps
Identity Verification	Confirming someone is who they claim to be	Help desk lacked adequate verification protocols

Analysis Questions

1. Describe the company featured in the case, including its competitive advantage (or “moat”), historical background, and the nature of its industry or business operations.
2. Summarize the key facts presented in the case. Do these facts relate to or mirror any other cases discussed in class? If so, what insights or lessons from those previous cases can be applied here?
3. Analyze the economic consequences of the information system failure described. If a similar failure occurred in today’s technological environment, would the impact be greater or smaller? How likely is such an incident to occur now?

4. Discuss the broader implications of the risks identified in the case for contemporary IT infrastructures, cloud computing services, and emerging artificial intelligence systems.
5. Identify the key human decision point in this case — the moment where a different choice by a person or team would most likely have prevented or significantly reduced the harm. Who was responsible, and what should they have done differently?
6. Identify and explain five key lessons or takeaways derived from this case study.

Discussion Questions

1. What does this case reveal about where organizations tend to underestimate risk — in their technology, their processes, or their people? Use specific evidence from the case to support your answer.
 2. If you were the CIO of the organization in this case, what are the first three changes you would make after this incident, and why?
 3. Caesars paid the ransom and suffered minimal disruption. MGM did not pay and suffered enormously. Develop a framework — before an attack occurs — that an organization could use to decide whether it would pay a ransom. What factors belong in that framework?
 4. The attack began with a LinkedIn search and a phone call. What does this tell us about where organizations should focus their cybersecurity investments? Is buying expensive technical software sufficient?
 5. MGM's help desk employee was following standard procedure and trying to help a colleague. How do you design verification systems that protect against social engineering without making legitimate employees' daily work miserable?
 6. What should MGM do differently going forward? Propose a specific set of policies and procedures — covering both technical and human dimensions — to prevent a similar attack.
-

Suggested Further Reading

- “MGM Resorts Cyberattack: What We Know” — [The Wall Street Journal](#) and [Reuters](#), September 2023
 - U.S. Securities and Exchange Commission (SEC) [filings](#) by MGM Resorts.
 - “Scattered Spider: The Hacker Group Behind the MGM Attack” — [Krebs on Security](#)
-

Instructions

1. Use **Bloomberg News** as the primary source for case research. You may also reference other *reputable* public websites or databases. All sources must be properly cited in **APA format** within your written report.
2. The **written case report** should be between **5 and 10 double-sided pages**, inclusive of tables, figures, infographics, or any analytical materials. Acceptable submission formats include **Canva, Microsoft Word, PDF, Markdown, or LaTeX**.

3. The **case presentation** should consist of **10 to 30 slides**, incorporating tables, charts, infographics, or analytical visuals as needed. Acceptable file formats include **Canva, Microsoft PowerPoint, PDF, Quarto Markdown, or LaTeX**.
4. Include a **detailed log of each team member's contributions** as an appendix to the written report. Every team member must be prepared to address questions during the presentation, both on the overall case content and specifically on the sections they contributed to.
5. **AI tools may not be used** to generate written content for the report. Collaborative work through **Google Docs** (with version control and simultaneous editing) is encouraged to demonstrate authentic team contribution and transparency in authorship. All version control tracking links must be shared with the instructor when asked.

*Prepared for Suresh Paul's MIS Course — Case Study Student Reading. Not intended for commercial use.
Not intended for AI training*